

Lodus — Verification & Access Control

Document version: 1.0

Project: Lodus (Next.js)

Last updated: May 2026

1. Purpose

This document lists every place Lodus verifies identity, ownership of contact details, staff approval, or access before allowing an action. It covers membership onboarding, login, profile setup, OTP flows, admin gates, and public roster rules.

2. Summary table

#	Verification type	What is checked	Mechanism	Primary files
1	Gmail application	@gmail.com / @googlemail.com, MX records	Server validation	src/lib/validation/email.ts, src/app/auth/actions.ts
2	Email ownership	User clicked verification link	Token email_verify !' GET /api/auth/verify-email	src/lib/auth/user-service.ts, src/app/api/auth/verify-email/route.ts
3	Staff approval	Member accepted	Approve/reject tokens or admin UI	user-service.ts, MemberApprovalsSection, /api/auth/application/decision
4	First login after approval	Recipient has approval email	Temporary OTP as password (hashed)	approveUser() in user-service.ts
5	Login gate	Approved + email verified	canUserLogin()	user-service.ts, src/lib/auth.ts
6	Password sign-in	Correct password	bcrypt	auth.ts (Credentials)
7	OAuth sign-in	Google/Discord + same gates	NextAuth providers	auth.config.ts, auth.ts
8	Admin OAuth	Admin email + Gmail	canAdminSignInWithGmail, cookie	staff.ts, auth.ts
9	Profile setup	Phone, photo, Discord, password	/profile/setup	src/app/profile/setup/actions.ts
10	Password change OTP	6-digit code	password_reset_otp token	src/app/profile/actions.ts
11	Phone verify OTP	6-digit code to email	phone_verify token	profile/actions.ts
12	Account deletion	Current password	bcrypt compare	deleteAccount in profile/actions.ts
13	Admin password reset	OTP when admin sets password	verifyOTP	src/app/admin/roster/actions.ts
14	Staff access	Role / admin email	requireStaff, permissions	auth.ts, permissions.ts
15	Public roster	Approved + phone on file	isRosterEligible	src/lib/queries/members-roster.ts

3. Membership onboarding

3.1 Application (Gmail)

- Applicants must use Gmail (gmail.com or googlemail.com).
- Format and local-part rules are enforced.
- DNS MX check confirms the domain can receive mail (not that the mailbox exists).
- **Function:** validateGmailForApplication()
- **Entry:** submitMemberApplication in src/app/auth/actions.ts

3.2 Email verification (link)

- After application, user receives a link with a one-time token.
- **Token type:** email_verify (stored in auth_tokens, ~24h).
- **Endpoint:** GET /api/auth/verify-email?token=...
- Sets users.emailVerified = true.
- **Functions:** sendVerificationEmail, verifyUserEmail in src/lib/auth/user-service.ts

3.3 Staff approval

- Staff notified by email with approve/reject links, or via **Member Approvals** in admin.
- **Token types:** approve, reject
- **API:** GET /api/auth/application/decision
- **On approve:** approveUser() sets status = "approved", generates a **temporary OTP password**, emails it to the member.

3.4 On reject

- status = "rejected"; canUserLogin() blocks sign-in.
-

4. Login verification

4.1 `canUserLogin()` gates

Condition	Result
status === "rejected"	Blocked
status === "pending"	Blocked
emailVerified === false (non-admin bypass)	Blocked
status === "approved" + verified email	Allowed (subject to profile/OAuth rules)

4.2 Email + password

- Provider: Credentials in src/lib/auth.ts
- Verifies passwordHash with bcrypt, then canUserLogin()

4.3 Google OAuth

- Provider in src/lib/auth.config.ts
- signIn callback applies approval and email rules

4.4 Discord OAuth

- Duplicate providerAccountId prevented
- Optional link via lodus_link_email cookie

4.5 Admin Google OAuth

- Requires ADMIN_EMAIL, Gmail check, lodus_admin_oauth cookie

4.6 Dev login (optional)

- Only when AUTH_DEV_MODE=true — passwordless email login

4.7 Post-login: profile incomplete

- No phone !' needsProfile !' /profile/setup
 - OAuth users without phone !' /login/complete first
-

5. Profile setup (post-approval)

Route: /profile/setup

Requirements: status === "approved"; session or setup_profile token.

Collected: name, password, phone, Discord handle, profile photo (required).

6. OTP verification (6-digit codes)

Token type	Purpose	Typical expiry
------------	---------	----------------

password_reset_otp	Password set/change	~10 min
phone_verify	Confirm phone	15 min

Changing phone resets phoneVerified until re-verified.

7. One-time link tokens (24h default)

Type	Purpose
------	---------

email_verify	Verify email
approve / reject	Staff application decision
setup_profile	Fallback profile setup access

8. Password & account security

Action	Verification
--------	--------------

Change password (has custom password)	Current password + OTP
Set first custom password	New password + OTP
Delete account	Current password

9. Admin & staff authorization

Check	Purpose
-------	---------

requireStaff()	Gate admin server actions
canApproveMembers()	Approve applications
Role permissions	approveMembers, manageRoles, etc.
Admin roster password change	OTP required

10. Public roster eligibility

- users.status === "approved"
- Phone on file (isRosterEligible), or @lodus.test
- Site admin email excluded from public directory

phoneVerified is not required for roster listing.

11. Gaps & non-verified areas

- Phone verification optional for public roster
 - No SMS — phone OTPs go to email
 - setup_profile link secondary to approval OTP login
 - Discord: duplicate check only
 - OAuth may skip manual email link if provider marks email verified
-

12. Typical member flow

Apply (Gmail) !' Email verify link !' Staff approve !' Email temp OTP
!' Login !' Profile setup !' [Optional] Phone OTP !' Roster visible

13. Key file index

Area	Path
-----	-----
User / tokens / approval	src/lib/auth/user-service.ts
Auth providers	src/lib/auth.ts, src/lib/auth.config.ts
Application	src/app/auth/actions.ts
Email verify API	src/app/api/auth/verify-email/route.ts
Application decision	src/app/api/auth/application/decision/route.ts
Profile OTP / phone	src/app/profile/actions.ts
Profile setup	src/app/profile/setup/actions.ts
Admin roster	src/app/admin/roster/actions.ts
Gmail validation	src/lib/validation/email.ts
Staff rules	src/lib/auth/staff.ts
Roster eligibility	src/lib/queries/members-roster.ts
Token types (schema)	src/lib/db/schema.ts